

信息技术安全评估准则 CC 与等级保护

北京大学计算机系信息安全研究室 段云所

1993年6月, TCSEC和ITSEC等信息技术安全评估准则的发起组织开始联合起来,将各自独立的准则组合成一个单一的、能被广泛使用的IT安全准则。这一行动被称为CC项目,它的目的是解决原标准中出现的概念和技术上的差异,并把结果作为开发中的国际标准提交给ISO.CC也成为中国制定等级保护制度的参考准则之一。

CC 的范围

CC重点考虑人为的信息威胁,无论其是有意的或无意的,不过,CC也可用于非人为因素导致的威胁。

CC适用于硬件、固件和软件实现的信息技术安全措施,而某些内容因涉及特殊专业技术或仅是信息技术安全的外围技术,因此不在CC的范围内,例如:

- * CC不包括那些与信息技术安全措施没有直接关联的属于行政管理安全措施的安全评估准则。这类管理安全措施在TOE的运行环境中被认为是TOE安全使用的前提条件;
- * CC不专门针对信息技术安全性的物理方面(诸如电磁辐射控制)的评估;
- * CC不涉及评估方法学,也不涉及评估机构使用CC的管理模式或法律框架;
- * 评估结果用于产品和系统认可的过程不在CC的范围之内;
- * CC不包括密码算法固有质量评价准则。

CC 的评估

为了使评估结果达到更好的可比性,评价应在权威的评估方案框架内执行,该框架规定了标准、监控评估质量并管理评估的工具,以及评估者必须遵守的规则。

CC并不规定对可调整框架的要求,但是,不同评估机构的可调整框架的一致性使评估结果可以互相认可的前提。

使用通用评估方法学可以提供结果的可重复性和客观性,但这仅靠方法学本身是不充分的。许多评估准则需要使用专家判断和一定的背景知识,而这些是很难达到一致性的。为了增强评估结果的一致性,最终的评估结果应提交给一个认证过程,该过程是一个针对评估结果的独立的检查过程,并生成最终的证书或正式批文。该证书通常是公开的。要说明的是,认证过程是使得IT安全准则的应用得到更好一致性

的一种手段。

评估方案、方法学和认证过程是管理评估方案的评估机构的责任,不属CC的范围。

CC 的组织

CC包括三个部分:

第一部分:简介和一般模型。这里介绍了CC的一般概念和格式,描述了CC的结构和适用范围,描述了安全功能、保证需求的定义,并给出了保护轮廓(PP)和安全目标(ST)的结构;

第二部分:安全功能要求。这一部分为用户和开发者提供了一系列安全功能组件作为表示评估对象(TOE)功能要求的标准方法,在保护轮廓(PP)和安全目标(ST)中将使用这些功能组件进行描述;

第三部分:安全保证要求。这一部分为开发者提供了一系列安全保证组件作为表示评估对象(TOE)保证要求的标准方法,同时还提出了七个评估保证级别(Evaluation Assurance Levels:EALs)。这七个评估保证级别分别是:

- EAL1:功能测试;
- EAL2:结构测试;
- EAL3:系统测试和检查;
- EAL4:系统设计、测试和复查;
- EAL5:半形式化设计和测试;
- EAL6:半形式化验证的设计和测试;
- EAL7:形式化验证的设计和测试。

CC 的一般模型

一般安全上下文

安全就是保护资产不受威胁,威胁可依据滥用被保护资产的可能性进行分类。所有的威胁类型都应该被考虑到,但是在安全领域内,被高度重视的威胁是和人们的恶意攻击及其它人类活动相联系的。

保护资产是资产所有者的责任。而实际或假定的威胁者希望以与所有者初衷相反的方式滥用资产。所有者将会意识到这种威胁可能致使资产损坏,对所有者而言资产中的价值将会降低。安全性损坏一般包括但又不仅仅包括以下几项:资产破坏性地暴露于未授权的接收者(失去保密性),资产由于

未授权的更改而损坏(失去完整性),或资产访问权被未授权的丧失(失去可用性)。

资产所有者必须分析可能的威胁并确定哪些存在于他们环境,其后果就是风险。这种分析会有助于对策的选择,以应对风险并将其降低到一个可接受的水平。

对策用以(直接或间接地)减少脆弱性并满足资产所有者的安全策略。在安全策略使用后仍会有残留的弱点,这些残留的弱点仍可以被威胁者利用,从而造成了资产的残余风险。资产所有者会通过给出其它的约束来寻求最小的残留风险。

在将资产暴露于特定威胁之前,所有者需要确信其对策足以应付面临的威胁。所有者他们自己可能没有能力对对策的所有方面加以判断,但可以寻求对策的评估。评估结果是对保证性可达到程度的描述,即对策能否被信任用于降低风险、保护资产。该描述还将对策的保证性进行分级。保证性是对策的特性,对策是正确操作时获得信心的基础。资产所有者可以根据此描述决定是否接受将资产暴露给威胁所冒的风险。

TOE评估

TOE评估过程的主要输入有:

- I. 一系列TOE证据,包括评估过的ST作为TOE评估的基础;
- II. 需要评估的TOE;
- III. 评估准则、方法和方案。

另外,说明性材料(例如CC的使用说明书)和评估者及评估组织的IT安全专业知识也常用来作为评估过程的输入。

评估过程的期望结果是对TOE满足ST中安全要求的确认,其方式是一个或多个由评估准则规定的评估人对TOE的裁决报告。这些报告对TOE所代表产品或系统的用户和潜在用户非常有用,对开发者也同样有用。

通过评估获得的信任度依赖于所达到的保证要求(即评估保证级别)。

评估过程通过两种途径导致产生更好的安全产品。评估过程能发现开发者可以纠正的TOE错误或弱点,从而在减少将来操作中安全失效的可能性。另一方面,为了通过严格的评估,开发者在TOE设计和开发时也将更加细心。因此,评估过程对最初需求、开发过程、最终产品以及操作环境将产生强烈的(尽管是间接的)积极的影响。

CC 安全概念

只有在IT环境中考虑IT组件保护资产的能力时,CC才是可用的。为了表明资产是安全的,安全考虑必须出现在所有层次的表述中,包括从最抽象到最终的IT实现。

CC要求在某层次上的表述包含在该层次上TOE描述的基本原理,那就是说,这个层次必须包含一合情合理的令人

信服的论据,表示它是和更高层次是一致的,而且它自己是全面的、正确的、而且内部一致的。通过陈述与安全目的的符合性,基本原理可以表明TOE在对抗威胁、执行组织性安全策略时的有效性。

CC将表述分成不同的层次,它阐明了一种在开发PP或ST时得出安全需求和规范的方法。所有的TOE安全要求根本上均来源于对TOE的目的和环境的考虑。这个图并不限制PP和ST开发的方法,它只是阐明一些分析方法的结果是怎么与PP和ST的内容相联系的。

安全环境

安全环境包括所有相关的法规、组织性安全策略、习惯、专门技术和知识。因此它定义了TOE使用的上下文,安全环境也包括环境里出现的安全威胁。

为建立安全环境,PP或ST的作者必须考虑以下几点:

- I. TOE物理环境,指所有的与TOE安全相关的TOE运行环境,包括已知的物理和人事的安全安排;
- II. 需要根据安全策略由TOE的元素实施保护的资产。这可能包括可直接相关的资产,如文件和数据库,也包括间接接受安全要求支配的资产,如授权凭证和IT实现本身;
- III. TOE目的,说明产品类型和可能的TOE用途。

安全目的

安全环境的分析结果被用来阐明对抗已标识的威胁、说明组织性安全策略和假设的安全目的,安全目的应和已说明的TOE运行目标或产品目标以及有关的物理环境知识一致。

确定安全目的的意图是为了阐明所有的安全考虑并指出哪些安全方面的问题是直接由TOE还是由它的环境来处理。这种划分需要工程判断、安全策略、经济因素和可接受的风险决策之间的协作。

环境安全目的将在IT领域内用非技术上的或程序化的手段来实现。

IT安全需求只涉及TOE安全目的和它的IT环境。

IT安全要求

IT安全要求是将安全目的细化为一系列TOE及其环境的安全要求,一旦这些要求得到满足,就可以保证TOE达到它的安全目的。

CC在不同种类功能要求和保证要求下提出安全要求。

CC的第2部分定义了功能要求,例如识别、鉴别、安全审计以及源不可抵赖功能等。

当TOE包括由概率或置换机制(例如口令和散列函数)实现的安全功能时,保证要求应规定与宣称的安全目的一致性的最小强度等级,此时,等级可为基本功能强度、中等功能强度、高等功能强度中的任意一个。要求这样的功能满足最小

的级别或至少是选择定义的特定级别。

对给定的一组功能要求,其保证程度可以是变化的,这种变化表现为保证组件级别严格性的增加。CC的第3部分使用这些组件定义了保证要求和一个评估保证级别的尺度。保证要求涉及开发者的行为,要产生的证据以及评估者的行为,例如:对开发过程的严格性约束,对查找并分析潜在安全弱点影响的需求。

通过合理选择的安全功能可以确保达到一定的安全目的,这种保证来源于以下两个因素:

对安全功能正确实现的信任,也就是评估它们是否被正确实现;

对安全功能的有效性的信任,也就是评估它们是否确实满足所陈述的安全目的。

安全要求通常包括出现期望行为和避免不期望行为。通过使用和检验,一般可以证明存在的期望行为。但一般不太可能明确证明不期望行为是不存在的。检验、设计审查、实现审查非常有助于减少存在不期望行为的风险。基本原理陈述有助于证明不存在不期望的行为。

TOE 概要规范

ST中提供的TOE概要规范定义TOE安全要求的实现方法。它提供了分别满足功能需求和保证需求的安全功能和保证措施的高层定义。

CC中安全要求的描述方法

CC定义了一系列与已知有效的安全要求集合相结合的概念,该概念可被用来为预期的产品和系统建立安全需求。用于需求描述的各种概念间的关系将在下面描述,见图7。

CC安全要求以类-族-组件这种层次方式组织,以帮助用户定位特定的安全要求。

对功能和保证方面的要求,CC使用相同的风格、组织方式和术语。

(1) 类:

类用作最通用安全要求的组合,类的所有的成员关注共同的安全焦点,但覆盖不同的安全目的。

类的成员被称为族。

(2) 族:

族是若干组安全要求的组合,这些要求有共同的安全目的,但在侧重点和严格性上有所区别。

族的成员被称为组件。

(3) 组件:

组件描述一组特定的安全要求集,它是CC定义的结构中所包含的最小的可选安全要求集。族内具有相同目标的组

件可以以安全要求强度(或能力)逐步增加的顺序排列,也可以部分地按相关非层次集合的方式组织。在某些实例中,一个族只有一个组件,因而不可能排序的。

组件由单个元素组成,元素是安全需求最低层次的表达,并且是能被评估验证的不可分割的安全要求。

* 组件间的依赖

组件间可能存在依赖关系。当一个组件无法充分表达安全要求并且依赖于另一个组件的存在时,依赖关系就产生了。依赖关系可以存在于功能组件之间、保证组件之间以及功能和保证组件之间。

组件间依赖关系描述是CC组件定义的一部分。为了保证达到TOE要求的完备性,当把组件加入到适当的PP和ST中时,应满足相应的依赖关系。

* 组件允许的操作

CC组件可以象在CC中定义的那样使用,或者通过使用组件允许的操作,对组件进行裁剪,以满足特定的安全策略或对付特定的威胁。每一个CC组件标识并定义了组件允许的“赋值”和“选择”操作、在哪些情况下可对组件使用这些操作,以及使用这些操作的后果。任何一个组件均允许“反复”和“细化”操作。这四个操作如下所述:

反复:在不同操作时,允许组件多次使用;

赋值:当组件被应用时,允许规定所赋予的参数;

选择:允许从组件给出的列表选定若干项;

细化:当组件被应用时,允许对组件增加细节。

一些需要的操作可以在PP内完成(整体或部分地),或者留在ST内完成,不过所有操作必须在ST内完成。

CC 中安全需求的描述方法

CC定义了三种类型的要求结构:包、PP和ST。

如果粗略的将关注信息系统或产品的人员分作三类:消费者、开发者与评估者,则可借助这三类人员不同使命来说明PP与ST的作用。

CC为所有的安全需求提供了一种通用的组件库,即可以根据具体的安全需求,从库中选择所需的组件——安全功能组件与安全保证组件。因此,可以说CC是知识库,是材料基地,包含了常用的安全技术。但一个具体的信息系或产品统有特定的安全需求,这些安全需求只是知识库的子集,如何将从知识库中选取的组件子集合理、有规律地表达出来,使得这种表达能够符合既定的安全目标,就需要一种描述方式,PP与ST正是这种描述方式。因此,如果说CC是一个完备的字典,则PP与ST就是组织字词的语法规则,按照这种规则组织字词所形成的语言,能充分表达自己的需求,并

且这些需求能覆盖既定的安全目标。

一般说来, PP是消费者表达自己需求的描述方式, 针对的是一类 TOEs, 而ST是开发者表达自己方案的描述方式, 针对具体的(Identified)TOE。因此, PP与安全功能的实现无关, 它回答的问题是“我们在安全方案中需要什么”, 是“目标”性的说明; ST依赖于实现, 回答的问题是“我们在解决方案中提供了什么(提供了什么安全措施)”, 是“建造”说明。CC对PP与S描述T的格式与内容表述均做出了结构化的规定。

(1) 包

组件的中间组合被称为包。包允许对功能或保证需求集合的描述, 这个集合能够满足一个安全目标的可标识子集。包可重复使用, 可用来定义那些公认有用的、能够有效满足特定安全目标的要求。包可用在构造更大的包、PP和ST中。

评估保证级别(EAL)是在CC第3部分中预先定义的保证包。一个保证级别是评估中保证要求的基线集。每一评估保证级别定义一套一致的保证要求, 合起来, 评估保证级别构成一个预定义CC保证级别尺度。

(2) 保护轮廓

保护轮廓(PP)包含一套来自CC(或明确阐述)的安全要求, 它应包括一个评估保证级别(EAL)(可能增加附加的保证组件)。PP是关于一系列满足一个安全目标集的TOE的、与实现无关的描述。PP可反复使用, 还可用来定义那些公认有用的、能够有效满足特定安全目标的TOE要求。PP也包括安全目的和安全要求的基本原理。

PP的开发者可以是用户团体、IT产品开发者或其它对定义这样一系列通用要求有兴趣的团体。PP为消费者提供了一套参照特定安全需求集的方法, 并提供了进一步评估这些安全需求的措施。

保护轮廓的描述结构如下:

(3) 安全目标

安全目标(ST)包括一系列安全要求, 这些要求可以引用PP, 也可以直接引用CC中的功能或保证组件, 或明确说明。ST是针对特定TOE安全要求的描述, 通过评估可以证明这些安全要求对满足指定目的是有用和有效的。

一个ST包含TOE的概要规范, 同时还包括安全要求和目的, 以及它们的基本原理。ST是所有团体间就TOE应提供什么样的安全性达成一致的基础。

CC 框架下的评估类型

(1) PP评估

PP评估是依照CC第3部分的PP评估准则进行的。这样

一个评估的目标是为了证明PP是完备的、一致的、技术合理的, 而且适合于作为一个可评估TOE的安全要求的声明。

(2) ST评估

针对TOE的ST评估是依照CC第3部分的ST评估准则进行的。ST评估具有双重目标: 首先是为了证明ST是完备的、一致的、技术合理的, 而且适合于用作相应TOE评估的基础。其次, 当某一ST宣称与某一PP一致时, 证明ST满足该PP的要求。

(3) TOE评估

TOE评估是使用一个已经评估过的ST作为基础, 依照CC第3部分的评估准则进行的。这样一个评估的目标是为了证明TOE满足ST中的安全要求。

(4) CC安全要求

CC的第二部分是安全功能要求, 对满足安全需求的诸安全功能提出了详细的要求, 另外, 如果有超出第二部分的安全功能要求, 开发者可以根据“类—族—组件—元素”的描述结构表达其安全要求, 并附加在其ST中。对各功能类的详细了解需要仔细阅读CC并在实际中加以应用。CC共包含的11个安全功能类, 如下:

- * FAU类: 安全审计
- * FCO类: 通信
- * FCS类: 密码支持
- * FDP类: 用户数据保护
- * FIA类: 标识与鉴别
- * FMT类: 安全管理
- * FPR类: 隐私
- * FPT类: TFS 保护
- * FAU类: 资源利用
- * FTA类: TOE 访问
- * FTP类: 可信信道 / 路径

CC的第三部分是评估方法部分, 提出了PP、ST、TOE三种评估, 共包括10个类, 但其中的APE类与ASE类分别介绍了PP与ST的描述结构及其评估准则; 对于已评估过的受测系统或产品, 保证维护类AVA旨在保证当运行环境发生变化后, TOE仍然能够满足安全目标。因此, 只有七个安全保证类是TOE的评估类别, 如下:

- * ACM类: 配置管理
- * ADO类: 分发与操作
- * ADV类: 开发
- * AGD类: 指导性文档
- * ALC类: 生命周期支持
- * ATE类: 测试
- * AVA类: 脆弱性评定